

ACG Security Evidence & Threat Mitigation Matrix

Zero-Trust Merchant Defense System

This document provides formal evidence classifications and test outcomes for all threat vectors evaluated against the Agent Commerce Gateway.

1. Threat Mitigation Matrix

Vector ID	Threat Description	Attack Vector Tested	ACG Defense Mechanism	Observed Outcome	Evidence Classification
SEC-01	Budget Overstep	Agent requests order exceeding mandate cap	Policy Engine Phase 4 check	HTTP 403 MANDATE_BUDGET_EXCEEDED	VERIFIED
SEC-02	Price Hallucination	LLM claims INR 1.00 unit price	Commerce Truth Engine DB lookup	Calculated INR 4,130.00 from DB	VERIFIED
SEC-03	Inventory Race	10 agents race for 1 stock unit	BEGIN IMMEDIATE SQLite lock	1 Allowed (201), 9 Blocked (409/400)	VERIFIED
SEC-04	Replayed Intent	Resending identical intent_id	order_sessions session gate	HTTP 409 DUPLICATE_INTENT_REPLAY	VERIFIED
SEC-05	Signature Forgery	Tampered budget/expiry post-signing	Ed25519 canonical verification	HTTP 401 INVALID_MANDATE_SIGNATURE	VERIFIED
SEC-06	Revoked Mandate	Valid signature on revoked mandate	Revoked Mandate Registry check	HTTP 403 MANDATE_REVOKED	VERIFIED
SEC-07	Webhook Forgery	Altered payload / forged HMAC	Constant-time HMAC SHA-256	HTTP 401 INVALID_WEBHOOK_SIGNATURE	VERIFIED
SEC-08	Webhook Replay	Repeated delivery of same event	processed_webhook_events table	HTTP 200 DUPLICATE_IGNORED	VERIFIED
SEC-09	SQL Injection	' OR '1'='1 in SKU string	Parameterized prepared SQL	HTTP 400 COMMERCE_TRUTH_REJECTION	VERIFIED
SEC-10	Cross-Merchant Reuse	Mandate for Merchant A sent to B	Whitelist array evaluation	HTTP 403 MERCHANT_NOT_WHITELISTED	VERIFIED
SEC-11	Audit Tampering	Adversary alters SQLite audit row	Forward SHA-256 hash chaining	Tamper detected via hash check	VERIFIED
SEC-12	Rail Failure	Downstream Razorpay API timeout	Fail-Closed dual rollback	HTTP 502 PAYMENT_RAIL_ERROR (0 loss)	VERIFIED

2. Evidence Classification Standard

* VERIFIED: Proven by automated vitest unit/integration tests and live HTTP penetration runner.

* OBSERVED: Empirically measured in real-time execution benchmarks.

* TESTED: Validated under isolated test harness conditions.

* DESIGNED: Architectural specification complete; awaiting upstream standard implementation.

* ADAPTER READY: Normalization interface implemented and verified with structured test fixtures.

* PRODUCTION TARGET: Enterprise capability designated for distributed cloud deployment.